PENINDAKAN · PURWARUPA LOKAL · DRAF REVIEW 13 NOVEMBER 2026

ValVuln AI

Dari laporan ke bukti yang bisa ditinjau.

Triage teks, pemeriksaan terdaftar di lab sendiri,
dan assessment admin yang terpisah dari prediksi AI.

ukas and codex vs everbody

Tim solo

CODE_TESTED lokal. Model live dan benchmark belum diverifikasi; bahan ini belum dipublikasikan.

MASALAH & PENGGUNA

Setiap laporan membutuhkan lebih dari satu jawaban “valid”.

Bug hunter

Mengirim klaim, konteks dan lampiran teks.

Perlu status serta informasi yang masih kurang.

Admin program

Memeriksa scope, bukti dan dampak.

Perlu alasan yang dapat dilacak ke observasi.

Risiko penilaian

Timeout atau bukti kurang bisa disalahartikan.

Hasil belum pasti harus tetap terlihat.

Ini motivasi desain. Belum ada pengukuran penghematan waktu, studi pengguna atau klaim adopsi instansi.

ALUR PRODUK

AI menyiapkan draf klaim. Backend menentukan izin.

Laporan → **Scope** → **Worker terbatas** → **Bukti** → **Review admin**

Triage teks eksplisit

Ekstraksi klaim dan identifier; pemilik memeriksa lalu mengonfirmasi.

Verifikasi terpisah

Observasi tersimpan, provenance dan hasil verifier.

Publikasi ringkasan

Admin meninjau sebelum hunter menerima ringkasan internal.

Model tidak memanggil tools, mengirim payload atau menugaskan worker. Planner pemeriksaan produk tetap deterministik.

BATAS KEMAMPUAN

Tiga jalur produk yang spesifik.

Jalur	Yang dicakup	Batas
BAC-08	Klaim penghapusan lampiran lintas pemilik	Objek, akun, kontrol dan snapshot tertentu
XSS-08	Marker fixture pada pratinjau notifikasi	Dua akun, rute dan fixture tetap
UP-04	Metadata nama lampiran yang dibaca akun lain	Bukan eksekusi isi file atau arbitrary upload

Business logic belum didukung validator produk. Sisa M6 DEFERRED untuk submission. Hasil historis tidak membuktikan semua subtype atau kondisi target saat ini.

Sumber: docs/r3-capability-map.md

INTEGRASI AI

Kontrak teks yang dibatasi.

Jalur UI

Triage terstruktur dengan label mode, provider dan status konfigurasi.

Mock terpisah dari live.

Jalur evaluasi A/B

`VALID / INVALID / ABSTAIN`

Alasan + referensi input yang divalidasi.

Biaya & integritas

Ledger aplikasi bersama, provider/model tetap, tanpa fallback benchmark.

Raw output disimpan sebelum review.

Adapter OpenRouter sudah diuji dengan HTTP simulasi. Key, akses/tier, harga/kurs, token bound dan smoke nyata masih diperlukan. Tidak ada klaim model live pada paket ini.

EVALUASI FUNCTIONAL-V2

Apakah bukti relevan membantu prediksi atas laporan yang sama?

A · Dokumen

Laporan + aturan publik terversi.

B · Dokumen + bukti

Input A + observasi terikat kasus dan disanitasi.

Target: 20 teks, 10 VALID / 10 INVALID, alokasi 8 BAC / 8 XSS / 4 upload.

Aktual: 20 kandidat, GT manusia 0, benchmark 40 slot belum dimulai. Metrik: belum tersedia.

Mekanisme dikenal saat development; bukan held-out akar masalah baru atau 20 bug independen. Simulasi schema/runner tidak dihitung sebagai hasil model.

Sumber: docs/evaluation.md

ARSITEKTUR LOKAL

Tiga service tetap.
Satu ledger aplikasi.

App

FastAPI · SQLite · UI Jinja2/JS

Login/role, scope, provider key, evidence dan assessment.

Worker

HTTP/browser terstruktur

Tanpa key model, GT, Docker socket atau jaringan publik.

Lab milik sendiri

Data sintetis · SQLite terpisah

Rute/fixture terdaftar, tanpa target pihak ketiga.

Evaluator merupakan perintah operator terpisah. Profil Compose opsional memakai volume app yang sama untuk ledger, tanpa mengaktifkan worker atau membaca GT ke prompt.

HASIL AKTUAL

Yang telah diuji dan yang masih menunggu input.

Aspek	Status paket review
Projection, runner, schema & ledger	CODE_TESTED dengan rekaman/HTTP simulasi
Startup/restart & paket source	Lihat bukti aktual di docs/final-review.md
GT dan bukti kandidat	Pending review manusia dan binding per kasus
LIVE_VERIFIED / FROZEN / EVALUATED	False; metrik benchmark null

Screenshot dan preview video memakai app disposable, mode MOCK dan rekaman sintetis. Tidak ada reproduksi target atau inferensi model pada pembuatan bahan ini.

REVIEW BERIKUTNYA

Siap ditinjau.
Input akhir masih diperlukan.

1. Tinjau kandidat dan bukti sebelum menetapkan GT.
2. Lengkapi akses model yang layak dalam budget.
3. Pilih lisensi proyek dan tinjau materi publik.
4. Lengkapi rekaman final, lalu otorisasi publikasi.

docs/final-review.md berisi indeks file dan hasil pemeriksaan.

READY_FOR_REVIEW_WITH_PENDING_INPUTS

Source baseline sudah di GitHub. Release final, video/slide publik dan submit formulir masih pending.